

AVANGARD SECURITY

Detail Layanan & Celah Keamanan Web

Cyber Defense untuk Aplikasi Web - dari pengujian, deteksi, hingga respons insiden.

Juni 2026 - stacopa-avangard.com

Bagian I - Detail Layanan

Enam layanan inti Avangard yang difokuskan pada keamanan aplikasi web, mencakup siklus pencegahan, deteksi, respons, dan kepatuhan.

1. VAPT & Ethical Hacking

Vulnerability Assessment & Penetration Testing

Simulasi serangan siber terkontrol terhadap aplikasi web Anda untuk mengekspos celah keamanan sebelum peretas jahat menemukannya.

- **Web Application Pentest:** Pengujian menyeluruh berbasis OWASP Top 10 (injection, XSS, broken access control, dll.).
- **API Security Testing:** Pengujian keamanan endpoint REST/GraphQL: autentikasi, otorisasi, dan rate limiting.
- **Authentication & Business Logic:** Pengujian manajemen sesi, privilege escalation, dan celah logika bisnis aplikasi.
- **Detailed Reporting:** Laporan teknis untuk tim IT dan laporan eksekutif untuk manajemen.

Metodologi: 01 Reconnaissance > 02 Scanning > 03 Exploitation > 04 Reporting

2. Managed Detection & Response (MDR)

Security Monitoring untuk Aplikasi Web & Cloud

Pemantauan keamanan berkelanjutan berbasis SIEM untuk aplikasi web dan cloud Anda. Sistem memantau otomatis sepanjang waktu, dengan analisis dan respons oleh tim ahli kami.

- **Continuous SIEM Monitoring:** Deteksi otomatis sepanjang waktu atas log aplikasi web, web server, WAF, dan cloud.
- **Expert Alert Triage:** Analisis memvalidasi alert (jam kerja + eskalasi kritis), memisahkan ancaman nyata dari false positive.
- **Threat Detection:** Identifikasi pola serangan & indikator kompromi (IoC) pada layer aplikasi & cloud.
- **Incident Response Support:** Eskalasi & pendampingan respons cepat saat insiden kritis terdeteksi.

Metodologi: 01 Log Ingestion > 02 Correlation > 03 Triage & Analysis > 04 Response

3. Incident Response

Emergency Response & Recovery

Layanan gawat darurat siber. Ketika Anda diserang ransomware atau malware, tim kami terjun langsung untuk mengisolasi, menghentikan penyebaran, dan memulihkan operasional sistem.

- **Ransomware & Malware Containment:** Isolasi cepat sistem yang terinfeksi untuk menghentikan penyebaran serangan.
- **System Recovery:** Pemulihan operasional bisnis dari backup yang bersih secara terkendali.
- **Root Cause Analysis:** Menentukan bagaimana serangan dapat terjadi untuk menutup celah penyebabnya.
- **Hardening & Post-Incident Report:** Rekomendasi perbaikan agar serangan serupa tidak terulang.

Metodologi: 01 Identification > 02 Containment > 03 Eradication > 04 Recovery

4. GRC & Compliance

Governance, Risk, and Compliance

Memastikan bisnis Anda memenuhi standar regulasi global dan nasional. Kami mendampingi dari gap analysis hingga audit readiness.

- **ISO 27001 Readiness:** Persiapan dokumen & kontrol teknis untuk sertifikasi.

- **UU PDP (Privacy Data):** Kepatuhan terhadap Undang-Undang Pelindungan Data Pribadi Indonesia.
- **IT Risk Assessment:** Identifikasi & valuasi risiko aset informasi perusahaan.
- **Policy Development:** Penyusunan SOP & Kebijakan Keamanan Informasi yang solid.

Metodologi: 01 Gap Analysis > 02 Implementation > 03 Internal Audit > 04 Certification

5. Secure Web Infrastructure

Web Hardening & Secure Deployment

Perancangan dan pengerasan infrastruktur web Anda agar aman sejak awal (security by design), dari konfigurasi web server hingga proteksi WAF dan secure deployment.

- **Web Server Hardening:** Pengerasan konfigurasi web server, OS, dan layanan mengikuti CIS Benchmark.
- **WAF & DDoS Protection:** Proteksi aplikasi web dari serangan OWASP dan trafik berbahaya pada layer aplikasi.
- **Secure Deployment & Config:** Konfigurasi hosting/cloud aman, TLS/HTTPS, manajemen secret, dan pipeline CI/CD aman.
- **Zero-Trust Access:** Penerapan prinsip never trust, always verify pada akses aplikasi & panel admin.

Metodologi: 01 Assessment > 02 Design > 03 Implementation > 04 Validation

6. Phishing Simulation & Training

Security Awareness Program

Program edukasi karyawan melalui simulasi serangan phishing nyata untuk meningkatkan kesadaran keamanan dan mengurangi risiko human error - pintu masuk serangan yang paling umum.

- **Realistic Phishing Campaign:** Simulasi email phishing terarah menyerupai serangan nyata.
- **Awareness Training:** Materi interaktif untuk mengenali & melaporkan social engineering.
- **Behavior Analytics:** Pengukuran click-rate & tingkat pelaporan untuk memetakan area berisiko.
- **Progress Reporting:** Laporan perkembangan kesadaran keamanan untuk manajemen.

Metodologi: 01 Baseline Test > 02 Simulation > 03 Training > 04 Re-assessment

Bagian II - 10 Celah Web yang Paling Sering Kami Temukan

Saat menguji keamanan aplikasi web klien (VAPT), kami telah menemukan 500+ celah keamanan. Berikut 10 jenis yang paling sering kami jumpai di lapangan, dijelaskan dengan bahasa sederhana agar mudah dipahami. Seluruhnya mengacu pada OWASP Top 10, standar industri untuk risiko keamanan aplikasi web. Detail temuan telah dianonimkan.

1 SQL Injection (SQLi)

OWASP A03: Injection

Severity: Critical

Penjelasan

Kolom isian di website (misalnya kotak login atau pencarian) bisa disisipi perintah rahasia. Karena website tidak memeriksa isian dengan benar, perintah itu ikut dijalankan ke database tempat semua data disimpan.

Yang kami temukan

Pada sebuah halaman login, cukup dengan mengetik kode singkat di kolom username, kami berhasil masuk sebagai admin tanpa tahu password aslinya.

Dampaknya

Seluruh isi database - termasuk data pelanggan dan password - dapat dicuri, bahkan server bisa dikuasai.

2 Cross-Site Scripting (XSS)

OWASP A03: Injection

Severity: High

Penjelasan

Penyerang menitipkan kode tersembunyi melalui kolom yang bisa diisi publik (misalnya kolom komentar). Saat orang lain membuka halaman itu, kode tersebut berjalan diam-diam di browser mereka.

Yang kami temukan

Kami menaruh kode tersembunyi di kolom komentar. Ketika admin membuka halaman tersebut, sesi login admin langsung dapat kami ambil alih.

Dampaknya

Akun korban (termasuk admin) bisa dibajak, dan tampilan website bisa diubah.

3 Broken Access Control (IDOR)

OWASP A01: Broken Access Control

Severity: High

Penjelasan

Setiap data biasanya punya nomor urut di alamat web. Bila website tidak mengecek apakah data itu memang milik Anda, cukup mengganti nomornya untuk melihat data orang lain.

Yang kami temukan

Dengan mengganti nomor pada alamat halaman tagihan (dari ...id=1001 menjadi ...id=1002), kami bisa melihat tagihan dan data milik pengguna lain.

Dampaknya

Data pribadi antar-pengguna bocor, dan fungsi khusus admin bisa diakses orang tak berwenang.

4 Autentikasi & Sesi Lemah (Brute Force)

OWASP A07: Identification & Auth Failures

Severity: High

Penjelasan

Website tidak membatasi berapa kali seseorang boleh salah memasukkan password. Penyerang bisa mencoba ribuan kombinasi password secara otomatis sampai tembus.

Yang kami temukan

Sistem login membiarkan kami mencoba password berkali-kali tanpa diblokir, sehingga akun dengan password lemah berhasil ditembus dalam hitungan menit.

Dampaknya

Banyak akun bisa dibajak sekaligus, terutama yang passwordnya mudah ditebak.

5 Security Misconfiguration

OWASP A05: Security Misconfiguration

Severity: Medium

Penjelasan

Pengaturan bawaan yang tidak dirapikan - seperti halaman admin yang terbuka untuk umum, atau pesan error yang membocorkan informasi teknis sistem.

Yang kami temukan

Halaman admin ternyata bisa dibuka siapa saja tanpa login, dan pesan error menampilkan detail teknis sistem yang seharusnya dirahasiakan.

Dampaknya

Penyerang mendapat peta sistem dan jalan masuk ke panel pengelola.

6 Kebocoran Data Sensitif

OWASP A02: Cryptographic Failures

Severity: High

Penjelasan

Data penting dikirim atau disimpan tanpa pengamanan (enkripsi) yang layak, atau kunci rahasia tertinggal di dalam kode website.

Yang kami temukan

Kami menemukan website yang belum memakai HTTPS, serta kunci akses (API key) yang tertulis terang-terangan di dalam kode halaman.

Dampaknya

Data bisa disadap di tengah jalan, dan kunci rahasia bisa disalahgunakan.

7 Cross-Site Request Forgery (CSRF)

OWASP A01: Broken Access Control

Severity: Medium

Penjelasan

Penyerang membuat korban yang sedang login tanpa sadar menjalankan sebuah aksi - misalnya mengganti email - hanya dengan mengklik tautan jebakan.

Yang kami temukan

Kami membuat sebuah tautan jebakan; saat korban yang sedang login mengkliknya, email akunnya berubah tanpa ia sadari.

Dampaknya

Data akun atau transaksi bisa diubah atas nama korban tanpa sepengetahuannya.

8 Server-Side Request Forgery (SSRF)

OWASP A10: SSRF

Severity: High

Penjelasan

Fitur yang meminta website mengambil data dari sebuah alamat bisa dibelokkan untuk mengakses sistem internal yang seharusnya tersembunyi.

Yang kami temukan

Lewat fitur 'ambil gambar dari alamat web', kami arahkan website untuk mengakses alamat internal penyimpanan kredensial cloud - dan berhasil.

Dampaknya

Akses ke sistem internal dan pencurian kredensial layanan cloud.

9 Unggah File Berbahaya (Webshell)

OWASP A05 / A03

Severity: Critical**Penjelasan**

Fitur unggah file (misalnya foto profil) tidak memeriksa jenis file, sehingga file berbahaya bisa diunggah lalu dijalankan di server.

Yang kami temukan

Melalui form unggah foto profil, kami berhasil mengunggah sebuah file program berbahaya, lalu menjalankannya untuk menguasai server.

Dampaknya

Penyerang bisa menjalankan perintah apa pun dan menguasai server sepenuhnya.

10 Komponen Usang & Rentan

OWASP A06: Vulnerable Components

Severity: High**Penjelasan**

Website memakai komponen atau plugin versi lama yang kelemahannya sudah diketahui umum, dan cara membobolnya tersedia bebas di internet.

Yang kami temukan

Kami menemukan sistem yang memakai plugin versi lama dengan kelemahan publik, yang bisa dibobol memakai alat yang tersedia gratis.

Dampaknya

Mudah diserang otomatis oleh bot, dan menjadi titik masuk awal peretas.

Temukan celah ini sebelum peretas melakukannya.

Hubungi Avangard Security untuk asesmen keamanan aplikasi web Anda.

Email: support@stacopa-avangard.com - Web: stacopa-avangard.com